Stoquify Platform Workflow System Audit — 2026-07-28

Executive verdict

Stoquify has a strong service-owned transaction foundation and unusually mature evidence, idempotency, reconciliation, and assurance concepts. It is not yet defensible as a platform-wide single source of truth or as production-certified. The most serious confirmed defects are: the accepted organization-scoped Prisma ADR is not implemented; generic bulk purchase-order approval bypasses the canonical maker-checker path; store-credit tender has no authoritative balance; electronic tender and non-cash refunds can become financially final without provider-authoritative evidence; and three read models disagree on the definition of cash collected. Release evidence also remains blocked for production database/migration history, managed secrets, statutory source hashes and expert approvals, external credentials, and operational governance.

This is a point-in-time audit of the current dirty filesystem, including uncommitted work. It is not a legal, statutory, accounting, security, or production-readiness certification. External providers and authority systems were not accessed and remain unverified.

Scope and method

The review combined repository governance, current source, Prisma schema and migrations, existing readiness evidence, knowledge-graph reports, bounded specialist reviews, and focused non-destructive tests. The graph report was used for navigation only: `graphify-out/GRAPH_REPORT.md` is dated 2026-06-14 and contains 4,121 nodes/5,321 edges with 709 inferred edges and 755 isolated nodes; current migrations and domains materially post-date it.

Current scale observed: 244 application TSX files, 21 application TS files, 217 action files, 593 service files, 1,101 test files, and 158 Prisma models. No direct `prisma.` call was found in the scanned `app`, `actions`, `lib`, `components`, or `hooks` TypeScript surfaces; persistence is concentrated in services. This positive result does not compensate for the missing DB-level tenant-scoping control.

Evidence labels used: **confirmed** means directly supported by current source or a successfully executed check; **inference** means evidence supports the conclusion but runtime behavior was not observed; **unverified** means required external/runtime evidence was inaccessible; **blocked** means a check or readiness prerequisite could not establish readiness.

Workflow family coverage

Family	Expected result	Authoritative owner	Status / principal gap
Identity and recovery	Authenticated, recoverable identity with controlled sessions	BetterAuth plus `services/users/*`	Implemented; invite tokens stored plaintext and critical audit is best-effort
Tenant and membership	Correct active organization and membership	organization/user services	Implemented; promised DB scoping layer absent

Family	Expected result	Authoritative owner	Status / principal gap
RBAC and entitlements	Only authorized and entitled actors mutate	RBAC, `protect`, module services	Partial; module gate is optional/observe-only on material actions
Settings, locations, terminals	Versioned operational configuration	organization/location/POS services	Implemented; cross-surface consistency not fully browser-verified
Master data	One tenant-owned customer/supplier/item catalog	domain services	Implemented; duplicate action/route facades increase drift risk
Inventory	Correct stock, movement, valuation, reversal evidence	inventory services	Strong CAS/event foundation; one atomic production consumption/output gate remains blocked
Purchase to pay	Approved order through receipt, match, release and settlement evidence	purchase-order and AP services	Strong AP controls; bulk PO approval bypass confirmed
POS and receipts	Atomic sale/stock/payment/ledger/receipt outcome	POS services	Strong transaction; store-credit/provider/refund/drawer concurrency gaps
Payment reconciliation	Provider/statement facts reconciled to operational payment truth	payment/reconciliation services	Strong suspense controls; external provider authenticity unverified
Accounting and close	Balanced, sourced ledger and evidence-gated close	accounting services	Strong source links/trust gates; statutory/migration prerequisites blocked
HRIS lifecycle	Controlled employee/contract/time/leave truth	HRIS services	Present; exhaustive browser and privacy validation not performed
Payroll	Approved payroll through declaration, payment, reconciliation and close	payroll services	Strong correction/provenance; provider and statutory conclusions unverified
Compliance/country packs	Versioned, sourced, expert-approved statutory behavior	compliance/regulatory services	Correctly blocked; Cameroon source hashes/approvals and placeholders unresolved
Approvals and overrides	Segregated, step-up, traceable decisions	domain services plus security services	Partial; PO bulk path and AI self-approval invariant gaps
Documents/evidence/export	Redacted, retained, provenance-backed evidence	evidence/export/domain services	Partial; critical audit durability and full redaction/access matrix unverified
Dashboards/read models	Fresh, provenance-labelled projections of canonical facts	dashboard/snapshot services	Partial; conflicting cash/AR semantics confirmed
Notifications/errors/incidents	Actionable, durable diagnosis and recovery	error/assurance services	Partial; external logging/alert transport not evidenced
Migration/backfill/deletion	Safe, reversible, traceable data evolution	Prisma/scripts/domain services	Hard-delete gate passes; migration history readiness blocked
Offline sync/replay	Idempotent conflict-aware convergence on canonical services	offline POS service	Strong hash/idempotency chain; original actor/replay authority ambiguous

Family	Expected result	Authoritative owner	Status / principal gap
AI/automation	Evidence-bound proposals under human authority	AI/agent services	Read-only/proposal boundaries strong; route permission supplied by caller and creator self-approval not blocked
Release/operations	Executable gates, observability, rollback and evidence	scripts/assurance/operations	Static gates strong; enterprise release register remains blocked
Public/external	Abuse-resistant public access and authenticated integrations	receipt/public boundary and provider adapters	Public receipt strong; webhook/provider signature workflow absent or unverified

Detailed machine-readable records and scores are in `STOQUIFY_PLATFORM_WORKFLOW_REGISTRY_2026-07-28.json`. Scores are audit estimates, not certifications.

Highest-risk inconsistencies

P0 — tenant defence contradicts accepted architecture

Confirmed, very high confidence. ADR `docs/architecture/decisions/0002-org-scoped-prisma-extension.md:11-23` promises an organization-scoped Prisma extension and explicit unscoped escape. Current `prisma/db.ts:7-23` exports a plain `PrismaClient` as both `db` and `prisma`; the promised extension file is absent. `protect` only detects literal `organizationId` / `orgId` fields, including nested `data` (`services/_shared/protect.ts:180-207`). Therefore every service filter is a single point of tenant-isolation failure.

Containment: prohibit new raw-client use, inventory every tenant-owned query, and add adversarial cross-tenant tests. Structural fix: implement the accepted scoped client or formally supersede the ADR with an equivalent fail-closed repository/RLS boundary and tightly reviewed unscoped escape.

P0 — purchase-order bulk approval bypasses maker-checker truth

Confirmed, very high confidence. Canonical single approval requires a real approver and requester/approver separation (`services/purchase-order/purchase-order.service.ts:732-777`). The bulk status path can set `APPROVED` without actor identity, leaves `approvedById` unset, and emits no canonical business event (`:973-1006`). Its action checks permission but uses a bespoke boundary (`actions/purchaseOrderWorkflow/purchaseOrderSystemAction.ts:62-85,271-283`). Synthetic timestamp-based status history cannot reconstruct the missing actor.

Containment: remove `APPROVED` from generic bulk transition. Correction: route each approval through one command with actor, step-up where required, maker-checker, append-only transition evidence, event emission, and atomic failure semantics.

P0 — store credit is accepted without an owned balance

Confirmed, high confidence. `STORE_CREDIT` input contains amount/reference only (`services/pos/pos.schemas.ts:73-92`). Sale commit totals it and posts a paid payment/liability debit without a customer-scoped store-credit account lookup, reservation, balance/version check, or decrement (`services/pos/pos.service.ts:1922-2026,2071-2083`).

Containment: disable store-credit tender. Structural addition: tenant/customer store-credit ledger with atomic reserve/consume/reverse commands and immutable evidence.

P1 — provider truth is asserted locally

Confirmed from observed paths, high confidence. Card/mobile-money/bank evidence is constructed from submitted reference strings, duplicate detection searches local payments, and POS marks non-credit payments paid without an acquiring adapter. Non-cash refunds are created directly as processed without provider refund execution evidence (`services/pos/pos.service.ts:1992-2031,2718-2757`).

Introduce provisional, authorized, captured, provider-accepted, settled, failed, and reversed states. Post provisional funds to clearing/suspense; require signed provider evidence and reconciliation before settlement truth. Provider refunds need deterministic idempotency, retry, and exception evidence.

P1 — cash, receivable, customer, and drawer truth can diverge

Confirmed, very high confidence. Dashboard cash counts only `PAID` ; tenant operating snapshot counts `PAID` and `PARTIAL` ; finance counts every sales-linked payment except `CANCELLED` , including pending/refunded amounts, and subtracts that set from AR. Separately, customer balance and drawer balance use read-compute-set without a version/current-value predicate (`services/pos/pos.service.ts:1846-1854,1953-1989`).

Define one metric contract for cash collected, receivables, refunds, settlement and as-of time. Make projections consume a canonical payment-truth adapter. Use ledger-derived or immutable transaction-derived balances with CAS/atomic increments and reconciliation.

P1 — trusted origin, audit durability, and invite token controls

Confirmed code findings, high confidence; deployment exploitability partly unverified. `lib/auth.ts:48-60,248-252` can add request-derived host/forwarded-host values to trusted origins. `lib/security/audit-log.ts:37-68` catches and swallows audit persistence failure and skips without an organization. Invitation bearer tokens are stored and queried plaintext (`services/users/user-identity.service.ts:718-739,795-799`).

Use a static normalized origin allowlist behind an explicitly trusted proxy; persist security-critical audit obligations transactionally via append-only outbox; store only invitation token digests and redeem with one conditional state transition.

P1 — entitlement and offline actor authority are incomplete

Confirmed code shape, medium-high confidence. `protect` only enforces a module when callers specify one. Material POS tender actions omit it; invite settings entitlement is observe-mode. Offline records persist device/session/location but not the accepted original actor, while replay calls the canonical sale using the current caller. This can block legitimate replay or obscure actor provenance.

Require module enforcement on every externally callable action, add dedicated offline replay permission/service identity, persist original actor at ingest, and retain canonical POS service execution.

P1 — statutory and release prerequisites remain blocked

Existing readiness evidence reports enterprise release `BLOCKED` : 2 of 12 blocker groups ready and 10 open. Production database/migration target, managed secrets, Cameroon source hashes/expert approval, provider/authority credentials, operational evidence, stable-tree governance, and phase gates remain unresolved. Statutory country-pack readiness is 10/12 with source hash verification and expert approval blocked. Prisma migration history is 5/8 with an unfinished row, unapplied repository migrations, and checksum mismatch. These are repository-generated assertions and were not independently verified against production.

High-risk end-to-end traces

POS happy path and correction

UI/action `actions/pos/tender.actions.ts` invokes `commitPOSSale`; the service validates tenant/session/cart and tenders, claims sale state, records stock movement, drawer/payment data, ledger postings, fiscal/evidence events and receipt in a transaction (`services/pos/pos.service.ts:1701-2268`). Focused offline tests passed 27/27. Refund loads a completed tenant sale and active session, rejects invalid/prior/on-account cases, reverses session/inventory/drawer, records refund and ledger reversal, then audit/business-event evidence (`:2626-2812`). Exactness gaps remain for external tenders, partial returns, store credit and concurrent balances.

Inventory happy path and blocked/replay path

`postInventoryStockEvent` requires an open period, creates a business event, uses version-guarded stock changes, writes movement/audit evidence, applies the event and invalidates close evidence (`services/inventory/inventory-stock-event.service.ts:560-732`). On insufficient/closed-period conditions it records a blocker. Replay idempotency is checked after blocker handling, so repeated blocked events may append duplicate blocker audit evidence. Existing inventory readiness is 4/5; atomic production consumption/output is blocked.

AP happy path and exception path

Invoice match and independent approval flow through approved bank destination and distinct requester/approver/releaser identities, ledger posting, outbound transaction and reconciliation evidence (`services/purchasing/ap-control.service.ts:1544-3195`). The outbound transaction remains pending/suspense until statement proof. Missing statement evidence opens an exception. A `findFirst` then `create` pattern can race into duplicate active exceptions without a matching uniqueness constraint. Focused AP/reconciliation/accounting tests passed 35/35.

Payroll/compliance happy path and blocked path

Provider inbox work is leased, bridged, retried on transient failure, and completed with settlement or exception evidence (`services/payroll/payroll-provider-inbox-settlement-worker.service.ts:195-284`). Accounting data trust checks posting/source links, statements, reconciliation, payroll proof, fiscal certification, offline conflicts and statutory blockers before certified export. Close exposes `COUNTRY_PACK_UNVERIFIED`. Focused payroll/compliance/country-pack tests passed 65/65, but authority sources/providers were not contacted; statutory readiness remains blocked.

Identity/public receipt happy path and failure path

Authentication uses BetterAuth, DB-fresh RBAC and session assurance; invite action requires fresh auth and two permissions, applies grant-ceiling and tenant-role checks, then accepts through an abuse-limited public path. Public receipt lookup requires a signed token; raw ID lookup returns not found. Tokens bind tenant/sale/jti/time and registry state; receipt responses hide customer contact; revocation requires permission, entitlement and fresh auth. Focused identity tests passed 5/5 and receipt tests passed 12/12. Remaining correction controls include token digest migration, transactional audit/outbox, concurrent invite redemption, and explicit legacy receipt-token cutover.

AI/agent happy path and human boundary

Protected actions derive tenant/actor, require fresh auth and create evidence-backed navigate/checklist/review proposals. Decision uses a compare-and-set update and emits a business event; acceptance does not execute a workflow. Agent tools are read-only and outputs are recursively sanitized. Focused tests passed 15/15. Before executable proposals, derive route permissions server-side and prohibit creator self-approval.

Strongest existing foundations

- Service-owned action-to-service-to-Prisma direction with no active boundary violations in the static scan.
- POS transaction connects sale, stock, drawer, payments, ledger, fiscalization, receipt and business events.
- Inventory optimistic concurrency and reversal lineage.
- Business-event idempotency/outbox, accounting source links, payroll correction/provenance hashes, and assurance incident-event history.
- AP three-way match, approved bank destinations, and multi-person segregation.
- Payment suspense, payroll provider leases/retries, and close/data-trust blockers.
- Public receipt token registry, redaction, revocation and fresh-auth controls.
- Snapshot contracts expose freshness, source hash, blockers and redaction instead of silently claiming authority.
- Static workflow assurance registry: 38/38 checks, 11/11 indexes and 2/2 engine-health gates ready.
- Hard-delete and service-boundary enforcement gates passed on the audited tree.

Top ten remediation priorities

1. Implement or formally supersede the org-scoped Prisma ADR with fail-closed tenant enforcement and adversarial tests.
2. Remove the PO bulk-approval bypass and make one append-only maker-checker state machine authoritative.
3. Disable then rebuild store credit on a tenant/customer-scoped immutable balance ledger.
4. Establish provider-authoritative tender/refund states, signed evidence, clearing/suspense and reconciliation.
5. Define canonical cash/AR/refund metric semantics and migrate every dashboard/report to shared fixtures/adapters.
6. Replace customer/drawer read-set updates with CAS/atomic/ledger-derived projections.
7. Make critical security/audit evidence transactional and append-only; hash invitation tokens and harden trusted origins.
8. Make module entitlement mandatory on external mutation boundaries; fix offline original-actor and replay authority.
9. Resolve migration history and managed-secret blockers, then verify external log/metric/alert transport and recovery drills.
10. Keep statutory/country-pack certification blocked until signed sources, effective dates, expert approval and authority conformance evidence exist.

Recommended implementation sequence

Phase 0 — containment: disable store credit; remove `APPROVED` from bulk status; freeze provider-local "settled" claims; reject unknown hosts; keep statutory/export gates blocked.

Phase 1 — trust boundaries: scoped database/RLS boundary, mandatory entitlement policy, transactional audit outbox, token digests, offline actor/replay authority.

Phase 2 — financial truth: provider tender/refund lifecycle, immutable store credit, customer/drawer concurrency, canonical payment migration policy.

Phase 3 — projection convergence: shared metric semantic catalog and fixtures; migrate dashboard/snapshot/finance reports; consolidate duplicate route/action facades.

Phase 4 — assurance and release: expand assurance coverage to identity/entitlement/HRIS/master data; resolve migration/secrets/observability; obtain statutory expert/authority evidence; conduct staged rollback and reconciliation drills.

Each phase must ship independently with compatibility adapters, tenant-scoped migrations, reconciliation reports, feature flags where needed, and rollback that preserves append-only evidence.

Verification command ledger

Exact command	Result	Relevant output	Attribution
`npm run prisma:validate`	passed	Prisma schema valid	Audited schema check passed
`npm run typecheck` (first attempt, 180s)	timed out	No compiler diagnostics before timeout	Tool/time budget, not evidence of workflow failure
`npm run typecheck` (rerun, 420s)	passed	`tsc --noEmit --pretty false`, exit 0	Audited tree typecheck passed at that instant
`npm run service:boundary:fail`	passed	0 active violations; 11 allowed test/mock/service findings	Static scanned boundaries only
`npm run hard-delete:fail`	passed	0 active unsafe hard deletes; 8 classified allowed	Static scanned callsites only
`npm run workflow:assurance:release-gate`	passed	38/38 checks, 11/11 indexes, 2/2 engine-health gates	Static/read-only; did not execute checks or enable enforcement
`npm test -- --runInBand actions/users/__tests__/sendInvite.authorization.test.ts actions/users/__tests__/public-identity-actions.test.ts`	passed	2 suites, 5 tests	Identity/invitation focused slice

Exact command	Result	Relevant output	Attribution
`npm test -- --runInBand "app/api/receipts/[receiptId]/__tests__/route.test.ts" services/pos/__tests__/public-receipt-token.test.ts services/pos/__tests__/public-receipt-token-registry.service.test.ts`	passed	2 discovered suites, 12 tests	Receipt route/token/registry slice; one requested path was not separately listed as a discovered suite
`npm test -- --runInBand services/pos/__tests__/offline-sync.service.test.ts actions/pos/__tests__/sync.actions.test.ts`	passed	2 suites, 27 tests	Offline ingest/replay slice
`npm test -- --runInBand services/ai/__tests__/copilot-proposal.service.test.ts actions/ai/__tests__/copilot-proposal.actions.test.ts services/agents/__tests__/agent-policy.service.test.ts`	passed	2 discovered suites, 15 tests	AI/agent policy slice; not proof of executable automation safety
`npm test -- --runInBand services/purchasing/__tests__/ap-control.service.test.ts services/reconciliation/__tests__/payment-suspense-workflow.service.test.ts services/accounting/__tests__/data-trust.service.test.ts`	passed	3 suites, 35 tests	AP/reconciliation/accounting trust slice
`npm test -- --runInBand services/payroll/__tests__/payroll-control.service.test.ts services/compliance/__tests__/compliance-center.service.test.ts services/regulatory/__tests__/country-pack.service.test.ts`	passed	3 suites, 65 tests	Payroll/compliance/country-pack code slice; no external/legal verification
`npm run workflow:assurance:runtime-check`	skipped	Would read configured runtime database; target safety/authority not established	Risk control, not a workflow pass/fail
`npm run policy:gates`	skipped	Composite includes report rewrites and runtime operations	Avoided modifying user-owned evidence/current data
`npm run module:surface:inventory`	skipped	Existing script writes repository reports	Avoided overwriting dirty-worktree artifacts
`npm run build:app`	skipped	Prior readiness says build passed; not independently rerun	Time/scope; no current build-pass claim made
Production provider/authority/webhook verification	unverified	No external access attempted	External dependency/access boundary

Total successfully executed focused tests: 159. No destructive Prisma command, migration, reset, seed, external write, or production-data mutation was run.

Unresolved blockers

- Dirty worktree prevents a clean committed-baseline assertion.
- Knowledge graph is stale/incomplete relative to current source.
- Production DB target and migration history are not release-ready.
- Managed independent release secrets are missing/weak per existing evidence.
- Country-pack source hashes, expert approval, provider credentials and authority conformance are unavailable.
- Production observability sink, delivery, paging, retention and recovery-drill evidence is absent.
- No webhook/provider signature and replay workflow was located; treat it as absent/unverified.
- UI/UX, accessibility, responsive and browser-level task completion were sampled from code/navigation but not exhaustively executed.
- Existing passing tests do not cover the newly identified concurrency, spoofed-host, audit-outage, store-credit, provider, self-approval and cross-tenant adversarial cases.

Narrow follow-up prompts

1. “Implement the accepted org-scoped Prisma boundary (or a formally approved RLS/repository equivalent) for one pilot domain, add a raw-client static gate and cross-tenant adversarial tests, and produce migration/rollback evidence without broad refactoring.”
2. “Remove the purchase-order bulk approval bypass and route all approval through one maker-checker state machine with actor identity, fresh-auth policy, append-only transition evidence, event emission, concurrency tests and compatibility rollout.”
3. “Contain and redesign POS tender truth: disable store credit, add an immutable store-credit ledger, introduce provider-authoritative tender/refund states, and prove idempotent reconciliation with focused tests.”
4. “Create one canonical cash/receivable/refund semantic contract and shared fixtures, then reconcile dashboard, tenant snapshot and finance projections without changing unrelated UI.”
5. “Harden identity/security evidence: static trusted origins, transactional critical-audit outbox, hashed invite tokens with one-time CAS redemption, and adversarial failure tests.”

Current truth versus proposals

Everything above under findings, traces, command results and blockers describes observed current evidence or explicitly labelled inference/unverified state. The remediation priorities and sequence are proposals only. No remediation was implemented in this audit.